DealSure v2 vs EsKrow+: Differences

Source: “DealSure — ออกแบบระบบใหม่ v2” (@Biw, 28 Oct 2026), compared with the current EsKrow+ design and demo · Prepared 29 Oct 2026

Deadline: the doc says the 3-minute pitch PowerPoint must be submitted by **30 Oct 2026**, named `ลำดับ_ชื่อทีม_Track_3MinPitch`, and cannot be changed after sending. Pitch day is **7 Nov 2026**.

TYPE 1 Updates: add to the current design without contradicting it

Mark each item to approve or reject it.

#	UPDATE FROM DEALSURE V2	DECISION
U1	**Phase 1 is on-us only:** buyer and seller both bank with the same bank. Cross-bank support comes in phase 2, using federated learning and MPC (multi-party computation). This answers our open question about who the seller can be.	☐ Approve ☐ Reject
U2	**The buyer can start it too:** a “Request a bank-backed deal” link the buyer sends to the seller. A seller who refuses is a warning sign in itself.	☐ Approve ☐ Reject
U3	**Seller check before a deal is created:** the account is not frozen and not flagged as a mule account.	☐ Approve ☐ Reject
U4	**Buyer check:** pass/fail only. The result is never shown to the seller (PDPA).	☐ Approve ☐ Reject
U5	**Step-up authentication:** face scan the first time, on a new device or for a large amount; a PIN otherwise.	☐ Approve ☐ Reject
U6	**Packing photo or video:** the seller records it in the app; required for held deals. Stored in WORM storage (write once, can't be edited) with its hash in the chain. Counters “empty box with a real tracking number”.	☐ Approve ☐ Reject
U7	**One listing QR per item, single quantity:** the item is marked sold the moment someone pays, so it can't be sold twice.	☐ Approve ☐ Reject
U8	**Architecture:** app → API gateway (token check, rate limit, WAF, idempotency key) → 5 services (Listing/QR, Deal, Risk, Payment, Shipment) → Kafka event bus → background work (Evidence, Risk pipeline, Case/Report, Admin console). While the user waits, the system only reads a cache and starts the transfer. All services are stateless and scale out.	☐ Approve ☐ Reject
U9	**Risk model:** rules + XGBoost + GraphSAGE (a graph model of the transfer network), computed in the background into Redis. External checks (police / AOC 1441 / CFR) over OAuth2 + mTLS, cached about 24 h, behind a circuit breaker.	☐ Approve ☐ Reject
U10	**Fail-safe:** if the Risk service is down, show yellow: “Can't check right now”. Never show green.	☐ Approve ☐ Reject

U11	**Audit log:** one hash chain per deal, plus a periodic Merkle root signed by the HSM, plus WORM storage. A single record can be proven without opening everything. Ours is one global chain.	☐ Approve ☐ Reject
U12	**Evidence Pack:** PDF + QR, created only when someone reports, then forwarded to AOC 1441 / police.	☐ Approve ☐ Reject
U13	**Admin:** registered device only, and every action needs two approvers. Their jobs: review the threat queue (fake QR scans, mule patterns), handle sellers who were wrongly rated risky, and forward cases to authorities. Every action goes into the hash chain.	☐ Approve ☐ Reject
U14	**Device and traffic protection:** app attestation (Play Integrity / App Attest, per OWASP MASVS) and a token-bucket rate limit per user, per device and per QR.	☐ Approve ☐ Reject
U15	**Fixes for 15 known weaknesses.** Examples: • New accounts get a lower limit and are held until they have deals with unique counterparties. • A clean-looking mule account that suddenly changes behaviour triggers a face scan and a temporary downgrade. • Graph checks catch buyers and sellers colluding to inflate a reputation. • Warning wording varies so people don't tune it out. • The false-positive rate is tracked as a KPI. • Disputes need a reason and a photo, and dispute counts are tracked per buyer.	☐ Approve ☐ Reject
U16	**Pitch material:** papers in groups A–H (warnings, victim psychology, P2P trust, mule detection, risk-based authentication, QR security, tamper-evident logs, cross-bank learning). Statistics: ages 20–29 are 28% of victims and 74% of cases come via Facebook. Demo data from the IBM synthetic AML dataset (Altman 2023), clearly labelled as simulated.	☐ Approve ☐ Reject

TYPE 2 Conflicts with the current design

Red IDs mark the decisions with the biggest effect. M1 is a competition rule, not a choice.

#	DEALSURE V2	ESKROW+ NOW	IMPACT	DECISION
M1	**No KBank / KBTG / K PLUS name or logo** anywhere in the product, prototype or demo. The feature has a neutral name: “DealSure”.	“K PLUS” and “EsKrow+” appear throughout the demo and the QR proof of concept.	**Required by the rules.** Rename everywhere.	☐ Take theirs ☐ Keep ours
M2	**The seller creates the deal** and gets a reusable QR for the shop or item, signed once by the HSM. A new deal is created on the server each time someone scans, and is bound to that buyer.	The buyer creates the deal (stage demo). The proof of concept uses one QR per deal, with the buyer binding and a 15-minute expiry inside the QR.	Rework the proof of concept. The “reuse an old QR” attack no longer applies; reuse is now blocked by the item's sold status.	☐ Take theirs ☐ Keep ours

M3	**Only risky deals are held.** Green: paid to the seller immediately. Yellow: held if the amount is unusual for this buyer. Red: always held. Prohibited: no pay button.	Every deal goes through escrow.	Changes the core model.	☐ Take theirs ☐ Keep ours
M4	**Money is held in the buyer's own account** (an earmark) and never leaves it. Whether this counts as escrow under the law is an open question for the mentor. Fallback: a transfer delay the buyer can cancel, or warnings and an Evidence Pack only.	Money moves to a bank escrow account under the Escrow Act B.E. 2551, with a contract signed by all three parties.	Changes the legal basis, the ledger panel and the "protected by law" lines in the demo.	☐ Take theirs ☐ Keep ours
M5	**Release after delivery:** the carrier reports delivered and the buyer taps "Received", or 48 h pass with no reply after delivery.	Release when the buyer confirms a bank-verified shipment ID, or 48 h after the verified ID. This was chosen explicitly earlier.	Needs a decision. Their version closes our known gap: the parcel never arrives after the buyer confirms.	☐ Take theirs ☐ Keep ours
M6	**Disputes:** the buyer taps "Dispute", with a reason and photo required. The deal moves to DISPUTED, where the two sides can settle (cancel, partial refund or reship). If they can't, the money stays held for up to about 7 days and an Evidence Pack goes to AOC / police. After that, any state freeze order applies. If there's no order, where the money goes is an open question.	A report before payment keeps the money held, and carrier records decide. Other disputes stay frozen (s.23) until the parties agree or a court rules. Product issues are out of scope.	New states: DISPUTED, MUTUAL, REPORTED. The bank still never decides disputes.	☐ Take theirs ☐ Keep ours
M7	The risk card shows **reason categories only, never thresholds**, so scammers can't tune around it. It also shows the seller's partly masked real name, account age as a range, and the count of successful deals with unique counterparties. On a red card the main button is "Don't pay yet", and paying is a secondary button behind a countdown.	An exact score of 86/100, with points for each signal.	Redesign the risk screen.	☐ Take theirs ☐ Keep ours
M8	**Shipment checks:** the number exists, was created after the deal, goes to the buyer's **province**, and isn't reused.	Also checks that the **recipient name** matches, and checks the full address.	Small. Ours is stricter.	☐ Take theirs ☐ Keep ours

M9	The QR payload is **COSE_Sign1** with a `kid`, signed with ECDSA P-256 or Ed25519; the key is kept in an HSM (FIPS 140-3).	A Thai QR (EMVCo) payload with the signature in a custom field.	Small. Ours remains a valid payment QR.	☐ Take theirs ☐ Keep ours
M10	No equivalent. Scanning an ordinary PromptPay QR gives no alert; the defense is “no bank-backed deal is a warning sign”.	A “fake QR” beat: the app warns when the seller swaps in an ordinary transfer QR.	An idea in ours that is missing from theirs.	☐ Take theirs ☐ Keep ours
M11	Target users aged 20–29, backed by the statistics.	Target users aged 22–30.	Minor.	☐ Take theirs ☐ Keep ours

> **Biggest decisions:** M3 + M4 (hold only risky deals, in the buyer's own account), M5 (release at delivery or at buyer confirmation) and M1 (renaming, which is required). Once these are decided, the system design is updated first, then the demo.